

System and Network Security

Dr. Ashok Kumar Das

Professor

Center for Security, Theory and Algorithmic Research
International Institute of Information Technology, Hyderabad

E-mail: *ashok.das@iiit.ac.in*

URL: <https://www.iiit.ac.in/faculty/ashok-kumar-das/>
<https://sites.google.com/view/iitkgpakdas/>

Application Layer Security:

Electronic Mail (E-mail) Security

- Virtually, in all distributed environments, e-mail becomes most extensively used network based application.
- Users expect to be able to, and so, send mail to others those who are connected directly (indirectly) to the public Internet, regardless to host operating system or communications suite.
- With the explosively growing reliance on e-mail for every conceivable purpose, there grows a demand for **authentication** and **confidentiality (privacy)** services.
- Two services mainly stand out as approaches that enjoy widespread use:
 - ▶ **Pretty Good Privacy (PGP)**
 - ▶ **S/MIME (Secure Multipurpose Internet Mail Extension)**

S/MIME (Secure Multipurpose Internet Mail Extension)



- S/MIME is an Internet standard approach to e-mail security that incorporates the same functionality as PGP.
- S/MIME is a security enhancement to the MIME Internet e-mail format standard based on technology from RSA Data Security.
- Although both PGP and S/MIME are on an IETF standards track, it appears likely that S/MIME will emerge as the industry standard for commercial and organizational use, while PGP will remain the choice for personal e-mail security for many users.
- S/MIME is defined in a number of documents—most importantly Request for Comments (RFCs) is 3370, 3850, 3851, and 3852.

Pretty Good Privacy (PGP)

- PGP is a remarkable phenomenon.
- Largely the effort of a single person, **Phil Zimmermann**, PGP provides a confidentiality and authentication service that can be used for **electronic mail** and **file storage** applications.
- In essence, Zimmermann has done the following:
 - ▶ Selected the best available cryptographic algorithms as building blocks.
 - ▶ Integrated these algorithms into a general-purpose application that is independent of operating system and processor and that is based on a small set of easy-to-use commands.
 - ▶ Made the package and its documentation, including the source code, freely available via the Internet, bulletin boards, and commercial networks such as AOL (America On Line).
 - ▶ Entered into an agreement with a company (Viacrypt, now Network Associates) to provide a fully compatible, low-cost commercial version of PGP.

PGP has grown explosively and is now widely used. A number of reasons can be cited for this growth.

- It is available free worldwide in versions that run on a variety of platforms, including Windows, UNIX, Macintosh, and many more.
- It is based on algorithms that have survived extensive public review and are considered extremely secure. Specifically, the package includes RSA, DSS, and Diffie-Hellman for public-key encryption; CAST-128, IDEA, and 3DES for symmetric encryption; and SHA-1 for hash coding.
- It was not developed by, nor is it controlled by, any governmental or standards organization. For those with an instinctive distrust of “the establishment,” this makes PGP attractive.
- PGP is now on an Internet standards track (RFC 3156; MIME Security with OpenPGP (<https://www.openpgp.org/>)).

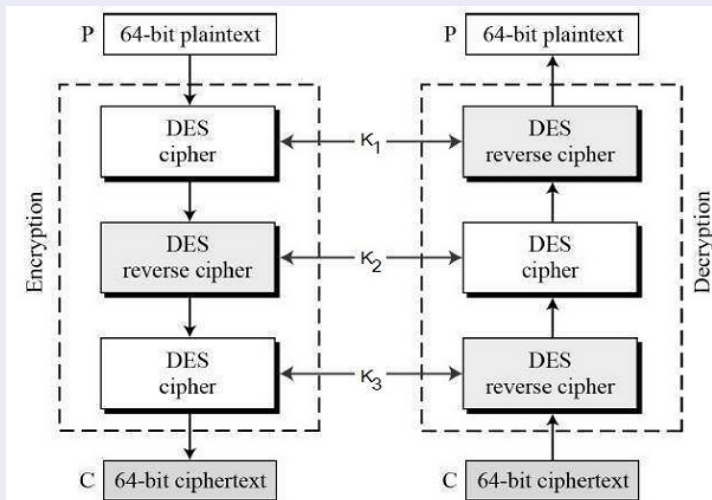
Notations used in PGP

- K_s = session key used in symmetric encryption scheme
- PR_a = private key of user A, used in public-key encryption scheme
- PU_a = public key of user A, used in public-key encryption scheme
- EP = public-key encryption
- DP = public-key decryption
- EC = symmetric encryption
- DC = symmetric decryption
- H = hash function
- $||$ = concatenation
- Z = compression using ZIP algorithm
- Z^{-1} = decompression using UNZIP algorithm
- $R64$ = conversion to radix 64 ASCII format

Cryptographic primitives used in PGP

Symmetric Encryption

Triple DES with Three Keys (3DES with Three Keys)



- **Symmetric Encryption**

- ▶ **IDEA (International Data Encryption Algorithm)**

- * It is a symmetric cipher that takes 64-bit plaintext block and a 128-bit key, and produces a 64-bit ciphertext block

- * Mathematically, $IDEA : \{0, 1\}^{128} \times \{0, 1\}^{64} \rightarrow \{0, 1\}^{64}$, that is, $IDEA_K(P) = C$, where $K \in \{0, 1\}^{128}$ is the key, $P \in \{0, 1\}^{64}$ is the plaintext block, and $C \in \{0, 1\}^{64}$ is the ciphertext block

● Symmetric Encryption

▶ **CAST**(**C**arlisle **A**dams and **S**tafford **T**avares)

* It is a symmetric block cipher named after the inventors **C**arlisle **A**dams and **S**tafford **T**avares.

* It takes 64-bit plaintext block and a 128-bit key, and produces a 64-bit ciphertext block

* Mathematically, $CAST : \{0, 1\}^{128} \times \{0, 1\}^{64} \rightarrow \{0, 1\}^{64}$, that is, $CAST_K(P) = C$, where $K \in \{0, 1\}^{128}$ is the key, $P \in \{0, 1\}^{64}$ is the plaintext block, and $C \in \{0, 1\}^{64}$ is the ciphertext block

Public Key Encryption

- RSA encryption
- ElGamal encryption

Digital Signature

- DSS (Digital Signature Standard)
- RSA signature

Hash Algorithms

- Secure Hash Algorithm (SHA)

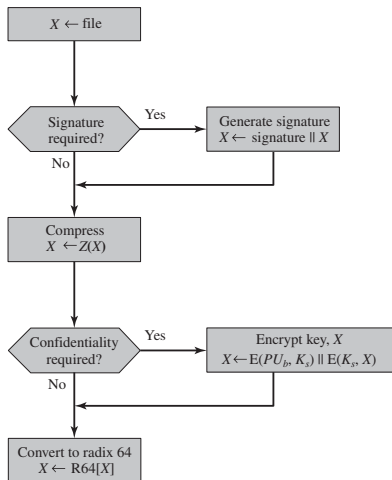
The actual operation of PGP consists of five services:

- (a) Authentication
- (b) Confidentiality
- (c) Compression
- (d) e-mail compatibility
- (e) Segmentation

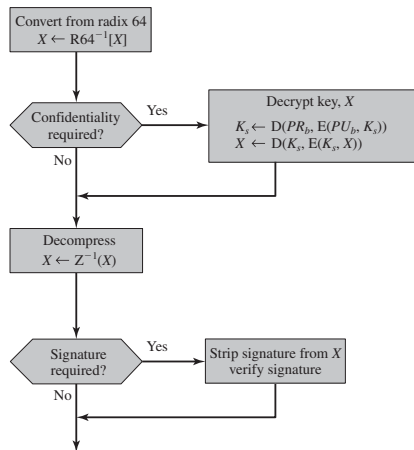
Summary of PGP Services

Function	Algorithms Used	Description
Digital signature	DSS/SHA or RSA/SHA	A hash code of a message is created using SHA-1. This message digest is encrypted using DSS or RSA with the sender's private key and included with the message.
Message encryption	CAST or IDEA or Three-key Triple DES with Diffie-Hellman or RSA	A message is encrypted using CAST-128 or IDEA or 3DES with a one-time session key generated by the sender. The session key is encrypted using Diffie-Hellman or RSA with the recipient's public key and included with the message.
Compression	ZIP	A message may be compressed for storage or transmission using ZIP.
E-mail compatibility	Radix-64 conversion	To provide transparency for e-mail applications, an encrypted message may be converted to an ASCII string using radix-64 conversion.

Transmission and Reception of PGP Messages



(a) Generic transmission diagram (from A)



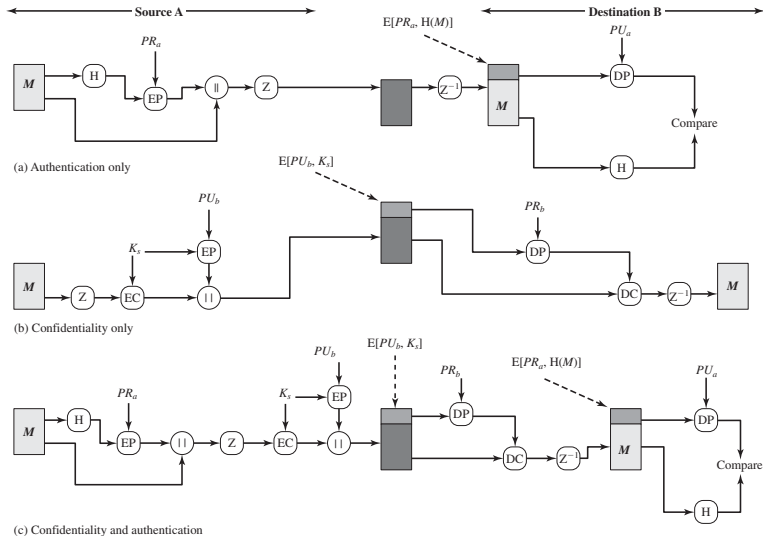
(b) Generic reception diagram (to B)

Authentication Only

The sequence is as follows.

- 1 The sender creates a message, say M .
- 2 SHA-1 is used to generate a 160-bit hash code of the message, $H(M)$.
- 3 The hash code is encrypted with RSA using the sender's private key (PR_a), and the result is prepended to the message ($EP_{PR_a}(H(M)), M$).
- 4 The receiver uses RSA with the sender's public key (PU_a) to decrypt and recover the hash code ($H(M)$).
- 5 The receiver generates a new hash code for the message ($H(M')$) and compares it with the decrypted hash code ($H(M)$). If the two match, the message is accepted as authentic.

PGP Cryptographic Functions



Confidentiality Only

The sequence is as follows.

- 1 The sender generates a message and a random 128-bit number to be used as a session key for this message only.
- 2 The message is encrypted using CAST-128 (or IDEA or 3DES) with the session key.
- 3 The session key is encrypted with RSA using the recipient's public key and is prepended to the message.
- 4 The receiver uses RSA with its private key to decrypt and recover the session key.
- 5 The session key is used to decrypt the message.

Confidentiality and Authentication

- First, a signature is generated for the plaintext message and prepended to the message.
- Then the plaintext message plus signature is encrypted using CAST-128 (or IDEA or 3DES), and the session key is encrypted using RSA (or ElGamal).
- This sequence is preferable to the opposite: encrypting the message and then generating a signature for the encrypted message. It is generally more convenient to store a signature with a plaintext version of a message.
- Furthermore, for purposes of third-party verification, if the signature is performed first, a third party need not be concerned with the symmetric key when verifying the signature
- In summary, when both services are used, the sender first signs the message with its own private key, then encrypts the message with a session key, and finally encrypts the session key with the recipient's public key.